

CYBERSECURITY FUNDAMENTALS

Technical Paper on the CIA Triad, Threat Modeling, Attack Vectors, and Baseline Security Controls

Internship Domain: Ethical Hacking

Prepared for: Workora Virtual Internship

Abstract

Cybersecurity protects information systems, applications, networks, and users from unauthorized access, disruption, modification, and destruction. This technical paper explains the three foundational objectives of security—Confidentiality, Integrity, and Availability (CIA). It also examines common attack vectors including phishing, ransomware, man-in-the-middle attacks, and SQL injection. Finally, it discusses threat modeling and practical baseline controls such as multi-factor authentication, encryption, and least privilege. The goal is to provide a concise foundation for understanding how organizations identify risks and reduce the impact of cyber threats.

1. Introduction to Cybersecurity

Cybersecurity is the practice of protecting digital systems and information from threats. Modern organizations depend on cloud services, databases, web applications, mobile devices, and connected networks, making security a continuous process rather than a one-time activity.

A useful security program begins by identifying what must be protected, understanding possible threats, estimating risk, and implementing controls. Security controls may be technical, administrative, or physical. They should be selected according to the sensitivity of the information and the potential impact of an incident.

2. The CIA Triad

The CIA Triad is a fundamental cybersecurity model consisting of Confidentiality, Integrity, and Availability. Together, these principles describe the core objectives of protecting information and services.

2.1 Confidentiality

Confidentiality means that information is accessible only to authorized people, systems, or processes. Controls such as access permissions, authentication, encryption, and data classification help maintain confidentiality.

Real-world failure example: If an attacker steals a database containing customer passwords or personal information and unauthorized people can read it, confidentiality has been violated.

2.2 Integrity

Integrity means that information remains accurate, complete, and protected from unauthorized modification. Hashing, digital signatures, access controls, audit logs, and file-integrity monitoring can help protect integrity.

Real-world failure example: If an attacker changes the amount of an online transaction without authorization, the integrity of the transaction data has been compromised.

2.3 Availability

Availability means that authorized users can access systems and information when needed. Backups, redundancy, disaster recovery, monitoring, capacity planning, and denial-of-service protection support availability.

Real-world failure example: A ransomware incident that prevents an organization from accessing its files can cause an availability failure even when the files have not been publicly disclosed.

CIA Triad Summary

Principle	Meaning	Example Control
Confidentiality	Prevent unauthorized disclosure	Encryption, authentication
Integrity	Prevent unauthorized alteration	Hashes, signatures, audit logs
Availability	Keep services and data accessible	Backups, redundancy, recovery

3. Threat Modeling

Threat modeling is a structured process for identifying what can go wrong in a system and deciding how to reduce the associated risks. A basic threat-modeling activity can identify assets, entry points, trust boundaries, threats, vulnerabilities, impacts, and appropriate mitigations.

A practical workflow is:

1. Identify assets such as credentials, databases, source code, and business services.
2. Identify possible attackers and their capabilities.
3. Map entry points such as login pages, APIs, email, remote access, and third-party integrations.
4. Identify threats and vulnerabilities that could affect confidentiality, integrity, or availability.
5. Estimate impact and likelihood, then prioritize risks.
6. Select controls and verify that mitigations reduce the identified risk.

4. Common Attack Vectors

4.1 Phishing

Phishing is a social-engineering technique in which an attacker attempts to trick a user into revealing information, opening a malicious attachment, visiting a fraudulent website, or approving an unwanted action. Effective defenses include security awareness training, phishing-resistant authentication, email filtering, link protection, and careful verification of unexpected requests.

4.2 Ransomware

Ransomware is malicious software designed to disrupt access to data or systems, commonly by encrypting files and demanding payment. Organizations can reduce impact through offline or immutable backups, patch management, endpoint protection, network segmentation, least privilege, and tested incident-response procedures.

4.3 Man-in-the-Middle (MitM)

A man-in-the-middle attack occurs when an attacker positions themselves between communicating parties and attempts to observe or manipulate traffic. Strong TLS/HTTPS, certificate validation, secure Wi-Fi configurations, VPNs where appropriate, and avoidance of untrusted networks reduce exposure.

4.4 SQL Injection

SQL injection occurs when untrusted input is incorporated into database queries in an unsafe manner, potentially allowing an attacker to alter query behavior. Parameterized queries or prepared statements, input validation, least-privileged database accounts, secure error handling, and regular application testing are important defenses.

5. Baseline Security Controls

5.1 Multi-Factor Authentication (MFA)

MFA requires two or more authentication factors, such as something the user knows, has, or is. It significantly reduces the risk associated with stolen passwords. Stronger methods include authenticator applications, hardware security keys, and phishing-resistant authentication mechanisms.

5.2 Encryption

Encryption transforms readable information into protected ciphertext so that unauthorized parties cannot easily interpret it. Encryption should be used appropriately for data in transit and sensitive data at rest, with keys managed securely.

5.3 Least Privilege

The principle of least privilege gives users, applications, and services only the permissions they need to perform their legitimate tasks. Limiting privileges reduces the potential damage if an account or application is compromised.

5.4 Additional Baseline Controls

Control	Security Benefit
Patch management	Reduces exposure to known software vulnerabilities
Backups	Supports recovery after accidental deletion or ransomware
Network segmentation	Limits movement between systems after compromise
Logging and monitoring	Helps detect suspicious activity and investigate incidents
Secure configuration	Removes unnecessary services and weak default settings
Security awareness	Reduces human-error and social-engineering risk

6. Threat Mitigation Strategy

No single control can eliminate every cybersecurity risk. Effective defense uses layers of protection. Organizations should combine prevention, detection, response, and recovery measures. For example, MFA can reduce account takeover, endpoint controls can detect malicious behavior, logging can support investigation, and tested backups can enable recovery.

Security controls should also be reviewed regularly because threats, software, business processes, and attacker techniques change over time. Risk assessments, vulnerability management, security testing, and incident-response exercises help maintain an effective security posture.

7. Conclusion

The CIA Triad provides a simple framework for understanding the primary goals of cybersecurity. Threat modeling helps organizations identify realistic risks, while understanding common attack vectors such as phishing, ransomware, man-in-the-middle attacks, and SQL injection helps security teams select suitable defenses. Controls including MFA, encryption, least privilege, patching, backups, monitoring, and security awareness provide layered protection. Together, these practices form a strong baseline for reducing cyber risk and improving organizational resilience.

References / Further Reading

- National Institute of Standards and Technology (NIST) — Cybersecurity Framework and security guidance.
- OWASP Foundation — Web application security guidance and OWASP Top 10.
- CISA — Cybersecurity guidance, ransomware resources, and security best practices.
- ISO/IEC 27001 — Information security management systems and controls.